SE – LAB – 05

NAME : SHIVANANDAN R

SRN: PES2UG24CS468

SEC : 5H

Before correction:

1. **Pylint report**

```
C:\Users\rshiv\Downloads>python.exe -m pylint eventmanager.py
************* Module eventmanager
eventmanager.py:79:0: C0304: Final newline missing (missing-final-newline)
eventmanager.py:1:0: C0114: Missing module docstring (missing-module-docstring)
eventmanager.py:9:0: C0116: Missing function or method docstring (missing-function-docstring)
eventmanager.py:9:0: C0103: Function name "createEvent" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:9:16: C0103: Argument name "eventName" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:9:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
eventmanager.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
eventmanager.py:15:0: C0103: Function name "registerGuest" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:15:18: C0103: Argument name "eventName" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:27:0: C0116: Missing function or method docstring (missing-function-docstring)
eventmanager.py:27:0: C0103: Function name "seatsLeft" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:27:14: C0103: Argument name "eventName" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:32:0: C0116: Missing function or method docstring (missing-function-docstring)
eventmanager.py:32:0: C0103: Function name "eventStatus" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:32:16: C0103: Argument name "eventDate" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:33:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
eventmanager.py:39:0: C0116: Missing function or method docstring (missing-function-docstring)
eventmanager.py:39:0: C0103: Function name "guestReport" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:39:16: C0103: Argument name "eventName" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:39:27: C0103: Argument name "sortOrder" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:39:27: W0613: Unused argument 'sortOrder' (unused-argument)
eventmanager.py:44:0: C0116: Missing function or method docstring (missing-function-docstring)
eventmanager.py:44:0: C0103: Function name "saveEvents" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:44:15: C0103: Argument name "fileName" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:49:0: C0116: Missing function or method docstring (missing-function-docstring)
eventmanager.py:49:0: C0103: Function name "loadEvents" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:49:15: C0103: Argument name "fileName" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
eventmanager.py:54:0: C0103: Function name "printBadges" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:54:16: C0103: Argument name "eventName" doesn't conform to snake_case naming style (invalid-name)
eventmanager.py:59:0: C0116: Missing function or method docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 4.46/10
```

2. **flake8 report**

```
C:\Users\rshiv\Downloads>python.exe -m flake8 eventmanager.py
eventmanager.py:61:43: E231 missing whitespace after ','
eventmanager.py:66:9: E225 missing whitespace around operator
eventmanager.py:75:28: E261 at least two spaces before inline comment
eventmanager.py:79:1: E305 expected 2 blank lines after class or function definition, found 1
eventmanager.py:79:7: W292 no newline at end of file
```

3. bandit report

```
C:\Users\rshiv\Downloads>python.exe -m bandit -r eventmanager.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.10.10
Run started:2026-10-14 06:22:18.609275+00:00

Test results:
>> Issue: [B403:blacklist] Consider possible security implications associated with pickle module.
   Severity: Low   Confidence: High
   CWE: CWE-502 (https://cwe.mitre.org/data/definitions/502.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b403-import-pickle
   Location: .\eventmanager.py:2:0
1       import os
2       import pickle
3       import random

--------------------------------------------------
>> Issue: [B301:blacklist] Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, possible security issue.
   Severity: Medium   Confidence: High
   CWE: CWE-502 (https://cwe.mitre.org/data/definitions/502.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b301-pickle
   Location: .\eventmanager.py:51:15
50          with open(fileName, "rb") as f:
51              return pickle.load(f)
52

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\eventmanager.py:56:4
55          # Helper kept for the lab: not called by the demo
56          os.system("lp badges_" + eventName + ".txt")
57

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\eventmanager.py:72:13
71          print("Alumni Dinner is", eventStatus(date(2020, 5, 1)))
72          winner = random.choice(events["Tech Meetup"]["guests"])
73          print("Lucky draw winner:", winner)

--------------------------------------------------

Code scanned:
        Total lines of code: 58
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 1
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 4
Files skipped (0):
```

Code Analysis Issues

Issue	Type	Line(s)	Description	Fix Approach
Shell command execution	Security - High	56	os.system() uses a command containing eventName, potentially allowing command injection. (B605)	Remove shell execution or use subprocess.run() with argument lists and shell=False.
Unsafe pickle loading	Security - Medium	51	pickle.load() can execute malicious code when loading untrusted files. (B301)	Use JSON or load only trusted pickle files.
Mutable default argument	Code quality	9	Default [] can be shared between function calls. (W0102)	Use None and create a new list inside the function.
Weak random generator	Security / randomness	72	random.choice() is unsuitable for security-sensitive selection. (B311)	Use secrets.choice() if security-grade randomness is required.
Naming convention	Style	9, 15, 27, 32, 39, 44, 49, 54	Function names and arguments use camelCase. (C0103)	Rename to snake_case and update calls.
Missing docstrings	Maintainability	Multiple	Module and functions lack descriptions. (C0114, C0116)	Add module and function docstrings.

Unused argument	Code quality	39	sortOrder is never used. (W0613)	Remove it or implement sorting.
Missing space after comma	Style	61	Missing whitespace after a comma. (E231)	Add a space after the comma.
Missing operator spacing	Style	66	Missing spaces around an operator. (E225)	Add spaces around the operator.
Inline comment spacing	Style	75	Insufficient spacing before an inline comment. (E261)	Add two spaces before #.
Unnecessary else	Maintainability	33	else follows a branch that already returns. (R1705)	Remove else and dedent its body.
Missing final newline	Style	79	File does not end with a newline. (C0304, W292)	Add a newline at the end of the file.
Incorrect blank lines	Style	79	Not enough blank lines after a function definition. (E305)	Add the required blank lines.

After correction:

1. **pylint report**

```
C:\Users\rshiv\Downloads>python -m pylint eventmanager.py

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 4.46/10, +5.54)
```

2. **flake8 report**

```
C:\Users\rshiv\Downloads>python -m flake8 eventmanager.py

C:\Users\rshiv\Downloads>
```

3. **bandit report**

```
C:\Users\rshiv\Downloads>python -m bandit -r eventmanager.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.10.10
Run started:2026-10-14 07:53:56.707834+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 69
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

Reflections:

1. What issues did the static analysis tools identify?

Pylint identified code-quality issues such as wrong naming, missing docstrings, a mutable default argument, and an unused parameter. Flake8 identified formatting errors, including missing whitespaces and blank-line problems. Bandit identified potentially unsafe shell execution, pickle deserialization, and use of a standard random generator.

2. Which issue was the most serious, and why?

The shell-command construction was potentially the most serious because untrusted input could influence a command executed by the operating system. Loading untrusted pickle files was also risky because deserialization can execute malicious code. Both issues required careful review rather than simply suppressing tool warnings.

3. How did you fix and verify the issues?

I improved function names, added docstrings, removed the mutable default argument, implemented sorting, and corrected formatting. I replaced pickle storage with JSON and addressed the subprocess-related findings. After making the changes, I reran Pylint, Flake8, and Bandit to check the results and ran the program to verify its behavior.

4. What did you learn from this exercise?

I learned that static-analysis tools identify different categories of problems and that no single tool catches every bug. A program can run successfully while still containing maintainability or security risks. I also learned to review each warning, apply an appropriate fix, and rerun tests after changing code.